PS-024: Privacy Pass Token Issuance and Anti-Replay Gateway

Aditya Narayan Dandia, Madhav Vinod, Pranav S S

adityandandia@gmail.com

Team CRYPOSYNACK • AIORI Hackathon 3 • October 12, 2026

A3-PS024-TC043

Problem Description

- IP-based rate limiting fails when many clients share one egress IP (shared proxies, VPNs, iCloud Private Relay)
- A server cannot tell one abuser from many legitimate users, so it must block everyone or allow everyone
- Anonymous tokens (Privacy Pass, RFCs 9576–9578) can replace the IP signal, but only if each token is redeemed exactly once
- Without replay protection, a copied token can be reused, which defeats the control

Background

- Blind signatures: the issuer signs a token without seeing it, so it cannot link a later redemption to the issuance. [1][2]
- Token fields (RFC 9577): type (issuance protocol), nonce (unique ID), challenge digest (binds it to one origin), key ID, signature.
- Tokens are bearer credentials: a copied token verifies again, so single redemption needs a replay cache.
- A token is valid only for the challenge it was issued for; a token from another context must be rejected.
- Proposed optimization: replace the IP signal with anonymous tokens and a replay cache that enforces single redemption.

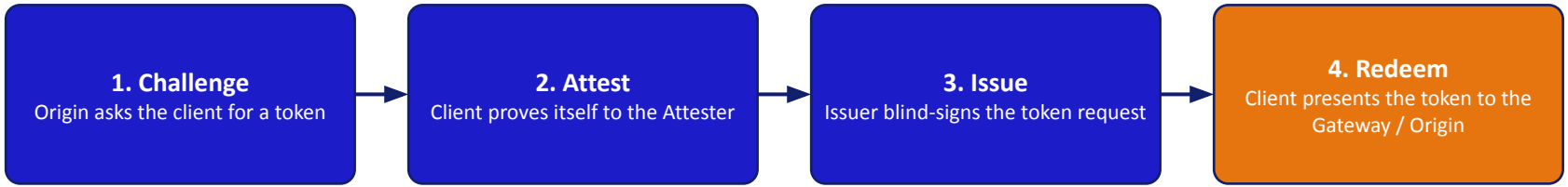


Figure: Privacy Pass token flow (RFC 9576 roles)

Literature & RFC Review

- Privacy Pass origin: anonymous CAPTCHA bypass using VOPRF tokens [1]
- RFC 9576: architecture, roles, privacy goals and deployment considerations [2]
- RFC 9577: PrivateToken HTTP authentication scheme (challenge / redemption) [3]
- RFC 9578: issuance protocols; we implement one of them, type 0x0002 (blind RSA) [4]
- RFC 9474 (RSA blind signatures) and RFC 9497 (OPRFs): the primitives, used as-is [5][6]
- Our contribution is integration and evaluation, not new cryptography.

Proposed Solution

- Integrate an existing Privacy Pass library; RFC 9578 type 0x0002 (blind RSA) as the single issuance protocol
- Lab setup: 1 controlled origin; issuer key and origin key kept isolated. The gateway holds only the issuer PUBLIC key; the private key never leaves the issuer
- Components: attester, issuer, client, edge verification gateway (fronting the origin)
- Gateway checks per redemption: (a) signature and key ID (invalid tokens); (b) challenge / origin context (wrong-context tokens); (c) nonce in replay cache, atomic insert with TTL (reused tokens)
- Shared-proxy test: several clients behind one egress IP, each redeems once
- Measure issuance and redemption latency; record metadata kept by issuer, client and gateway

Optimizations Proposed

Aspect	Before (IP rate limiting)	After (Privacy Pass gateway)	Methodology
Client signal	Egress IP: shared by many users behind a proxy	Anonymous token, independent of IP	Shared-proxy test: several clients, one egress IP, each obtains and redeems its own token
Reuse control	Limits an IP, not an individual client	Single redemption per token via replay cache	Redeem the same token twice; second attempt must be rejected
Replay check	Not applicable	Atomic insert of nonce with TTL: no check-then-write race	Redeem one nonce concurrently; exactly one ACCEPT
Privacy	Request history tied to IP	Token carries no identity; issuance and redemption not linkable (under stated assumptions)	Metadata inventory at issuer, client and gateway; confirm token holds no identity
Cost	Cheap counter lookup	Extra verify + cache step; latency measured, not assumed	Time issuance and redemption; compare with an IP-counter baseline

Solution Architecture & Design

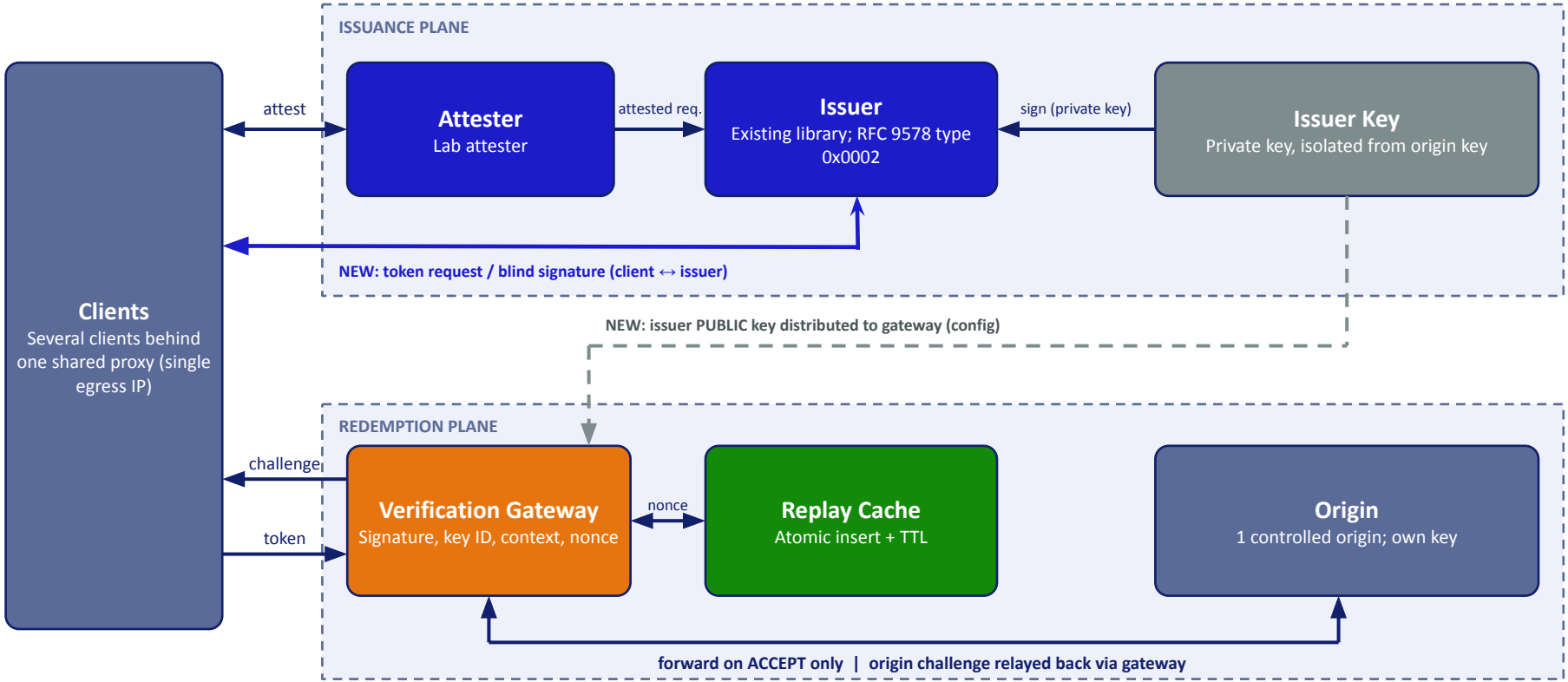
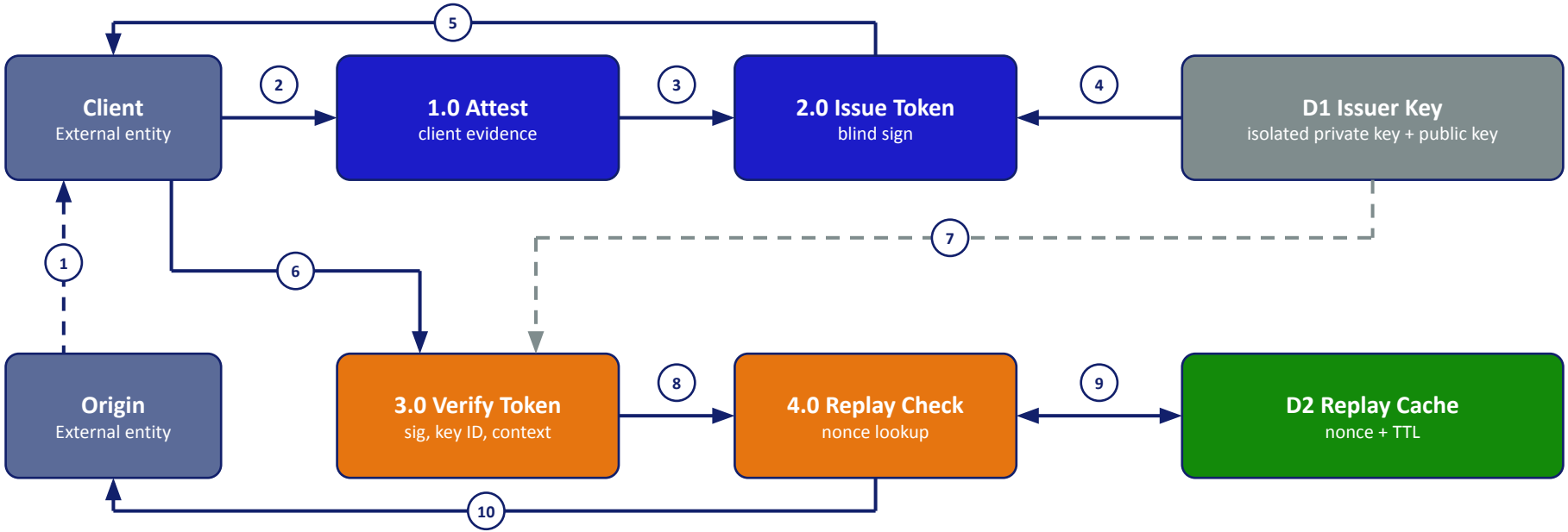


Figure: Lab architecture: RFC 9576 roles with an edge verification gateway. Blue/dashed = flows added in this revision.

Data Flow Diagram



1 challenge (Origin → Client)
2 attestation evidence
3 attested request + blinded message
4 signing key (private, issuer only)
5 blind signature → Client

6 token (nonce, key ID, signature): Client → gateway
7 issuer PUBLIC key (config) → Verify
8 verified token → replay check
9 nonce lookup / insert (atomic, TTL)
10 ACCEPT → forward to Origin; REJECT → Client

Deployment Timeline

Phase	Milestone	Methodology	Owner
1	Repo setup; pick Privacy Pass library; generate isolated issuer and origin keys	Choose library by RFC 9578 type 0x0002 support; generate separate RSA keys for issuer and origin	Pranav
2	Issuer and client: end-to-end issuance (RFC 9578 type 0x0002)	Run full challenge, attest, issue, redeem flow; client unblinds and verifies the signature	Aditya
3	Verification gateway and replay cache; single redemption	Check signature, key ID and context; atomic nonce insert with TTL; build one component at a time, test before the next	Aditya, Madhav
4	Tests: invalid, reused, wrong-context tokens; shared-proxy scenario	Negative tests (tampered, reused, wrong-origin tokens); several clients behind one egress IP, one redemption each	Pranav
5	Latency measurements (issuance, redemption)	Repeated timed runs on the working build; report median and p95 for issuance vs redemption	Madhav
6	Threat model, unlinkability and metadata analysis; PDF and demo with pseudocode	Threat model; list metadata held by issuer, client and gateway; state unlinkability assumptions	All

Bibliography

[1] A. Davidson et al. "Privacy Pass: Bypassing Internet Challenges Anonymously." PoPETs 2018(3), pp. 164–180.

[2] A. Davidson, J. Iyengar, C. A. Wood. RFC 9576: The Privacy Pass Architecture. 2024.

[3] T. Pauly, S. Valdez, C. A. Wood. RFC 9577: The Privacy Pass HTTP Authentication Scheme. 2024.

[4] S. Celi et al. RFC 9578: Privacy Pass Issuance Protocols. 2024.

[5] F. Denis, F. Jacobs, C. A. Wood. RFC 9474: RSA Blind Signatures. 2023.

[6] A. Davidson et al. RFC 9497: Oblivious Pseudorandom Functions (OPRFs) Using Prime-Order Groups. 2023.

Thank You for Your Attention!